

NorthStream Technologies

Compliance Assessment Plan – Executive Summary

Course: Cybersecurity Legislation and Compliance Assessments

Student: HASSANI Mohammad Salem

Date: January 25, 2026

Instructor: Asen Grozdanov

EXECUTIVE SUMMARY

This Compliance Assessment Plan defines the scope, methodology, and 10–12 week roadmap for a comprehensive cybersecurity compliance assessment of **NorthStream Technologies Inc.**, a mid-sized Canadian SaaS provider (250 employees, Toronto headquarters). NorthStream processes personal information across Canada, the United States, and the European Union via AWS-hosted cloud infrastructure[1].

Assessment Scope:

- Production SaaS platform: 8–10 Linux web servers (Ubuntu 22.04 LTS), AWS infrastructure
- Database tier: PostgreSQL 14.x (RDS), Amazon S3 buckets with customer & authentication data
- Identity systems: Azure AD (Entra ID) for employees, OAuth 2.0 + bcrypt for external users
- Employee endpoints: 30–40 Windows 11 Enterprise & macOS 13+ systems
- Network security: AWS WAF, Security Groups, VPC Flow Logs, Cisco VPN

Regulatory Framework:

- **PIPEDA** – Principle 4.7 (Safeguards) for Canadian customer & employee data[1]
- **GDPR** – Articles 32 (Security), 33 (Breach Notification) for EU customer data (150 customers in France, Germany, Netherlands)[1]
- **Quebec Law 25** – Articles 3–8 (Privacy Officer), Articles 14–18 (Information Security Program)[1]
- **CIS Benchmarks** – Technical compliance baseline for Linux, Windows, PostgreSQL, AWS[2]
- **NIST CSF 2.0** – Assessment framework: Govern, Identify, Protect, Detect, Respond, Recover[3]

Assessment Team & Cost:

- 4–5 full-time external assessors (Lead Auditor, 2 Technical Assessors, Compliance Analyst): CAD \$60K–80K
 - NorthStream internal resources: CISO, IT Operations Manager, Privacy Officer (part-time support)
 - **Estimated total cost:** CAD \$75K–120K including tools, consulting, analysis
 - **Timeline:** January 27 – April 21, 2026 (10–12 weeks, 5 phases)
 - **Deliverable:** Comprehensive assessment report with findings, risk ratings, and remediation roadmap
-

PHASE STRUCTURE & TIMELINE

Phase 1: Preparation & Planning (Weeks 1–2, Jan 27 – Feb 10)

Activities: Kick-off meeting, governance establishment, scope confirmation, tool provisioning, stakeholder onboarding

Deliverables: Kick-off minutes, assessment procedures manual, tool deployment checklist, risk assessment

Phase 2: Documentation & Interviews (Weeks 3–4, Feb 10 – Feb 24)

Activities: Policy review (7 mandatory documents), 8–10 stakeholder interviews (CISO, Privacy Officer, IT Ops), NIST CSF maturity baseline

Deliverables: Policy gap list, interview findings, current-state maturity assessment, control mapping matrix

Phase 3: Technical Assessment (Weeks 5–7, Feb 24 – Mar 17)

Activities: CIS Benchmark scanning (Linux/Windows/AWS/PostgreSQL), encryption audit, database hardening, endpoint assessment, network security review

Key Tools: OpenSCAP (Linux), Nessus (Windows), AWS Config (cloud), manual database audit

Deliverables: CIS scan results, encryption audit report, database assessment, endpoint compliance report, gap log

Phase 4: Findings Analysis (Weeks 8–9, Mar 17 – Mar 31)

Activities: Gap analysis & categorization by severity (Critical/High/Medium/Low), root cause analysis, control validation testing, SOC 2 third-party review (Okta, GitHub, Salesforce)

Deliverables: Comprehensive findings log, updated NIST CSF maturity assessment, SOC 2 CUEC verification, draft findings presentation

Phase 5: Report & Presentation (Weeks 10–12, Mar 31 – Apr 21)

Activities: Final report writing, remediation roadmap development (90–180 day timelines), executive presentation, Phase 2 planning

Deliverables: Final Compliance Assessment Report, remediation roadmap, executive presentation deck, metrics summary

ASSESSMENT METHODOLOGY

Framework-Based Approach (NIST CSF 2.0)

Assessment organized by six CSF Functions with specific evaluation focus[3]:

Govern (GV): Leadership structures, risk management strategy, organizational policies, Privacy Officer appointment per Law 25 Articles 3–8. Success criteria: Privacy Officer designated, Board-level cybersecurity oversight, documented risk management strategy.

Identify (ID): Asset inventory, data classification, business environment understanding. Success criteria: Current inventory of systems & data types with classification; documented mission & critical functions; asset-based risk register.

Protect (PR): Access control (least privilege, MFA, audit logging), encryption at rest/in transit, data handling training. Success criteria: RBAC implemented; MFA enabled for administrative access; encryption enabled for sensitive data; annual staff training completed; **CRITICAL for this assessment: AWS KMS Customer Master Keys for EU backup data per GDPR Schrems II compliance**[1].

Detect (DE): Security monitoring, log aggregation, incident detection procedures. Success criteria: Centralized log collection (CloudWatch/Splunk); real-time alerts; documented incident detection process; categorization procedures.

Respond (RS): Incident response procedures, breach containment, regulatory notification. **CRITICAL: Incident Response Plan must explicitly address:**

- **GDPR Article 33** – 72-hour notification to Data Protection Authorities (CNIL-France, BfDI-Germany, AP-Netherlands)[1]
- **Quebec Law 25** – 24-hour notification to Commission d'Accès à l'Information (CAI, faster than GDPR)[1]
- **PIPEDA** – Risk-based customer notification procedures for Canadian data[1]

Recover (RC): Backup & disaster recovery procedures, RTO/RPO definition, resilience testing. Success criteria: Backup policy documented (frequency, retention, encryption); RTO/RPO defined; annual recovery testing; critical systems redundancy.

Technical Assessment Methods

Configuration Compliance Scanning:

- **Linux (8–10 servers):** OpenSCAP scanning against CIS Ubuntu Linux 22.04 LTS Benchmark v1.1.0 (target >85% compliance)[2]
- **Windows (sample 10 systems):** Nessus Policy Compliance against CIS Windows 11 Enterprise Benchmark v3.1.0[2]
- **AWS Infrastructure:** AWS Config automated checks against CIS AWS Foundations Benchmark v2.0.0 (IAM, logging, networking, encryption)[2]
- **PostgreSQL Database:** Manual audit + SQL queries against CIS PostgreSQL 14 Benchmark v1.2.0 (authentication, access control, logging, encryption)[2]

Administrative Assessment:

- Policy review (7 mandatory documents: security policy, incident response plan, data classification, access control, encryption policy, vendor management, training program)
- Stakeholder interviews (CISO, IT Operations Manager, Privacy Officer, HR Manager, Technical Liaison) with minimum 10 standardized questions
- Third-party SOC 2 review: Okta, GitHub, Salesforce, AWS – verify audit scope, identify Complementary User Entity Controls (CUECs), confirm implementation

Gap Analysis & Severity Rating

Gap Types:

- **Control Gap:** Control does not exist (Example: Privacy Officer not appointed per Law 25 Articles 3–8) → Usually **CRITICAL**
- **Implementation Gap:** Control exists but partially/incorrectly implemented (Example: Incident response plan exists but lacks GDPR 72-hour DPA notification procedures) → Usually **HIGH**
- **Documentation Gap:** Control exists functionally but not documented (Example: Access control enforced in practice but no written policy) → Usually **MEDIUM/LOW**

Severity Levels:

- **CRITICAL:** Regulatory violation resulting in major fines (EUR €8–15M GDPR, CAD \$100K–1M Law 25); potential major data breach; violates core security principle
- **HIGH:** Non-compliance with important regulatory requirement; significant data loss/breach risk; partial critical control implementation
- **MEDIUM:** Non-compliance with framework best practice; operational issue; minor regulatory gap (e.g., CIS compliance at 75% vs 85% target)
- **LOW:** Documentation improvement; minimal regulatory/business impact

Each gap is mapped to: regulatory requirement (GDPR Article 32, PIPEDA Principle 4.7, Law 25 Article 14), NIST CSF control (GV.OC-01, PR.AC-01, RS.RP-01), and CIS Benchmark control with remediation recommendations, timeline, and estimated cost[1].

RESOURCE REQUIREMENTS & REPORTING

Assessment Team:

- Lead Auditor (CISM/CISSP, 10+ years; CAD \$150–200/hour, ~400 hours)
- Technical Assessors (2 Linux/Windows/AWS specialists; CAD \$120–150/hour, ~800 hours)
- Compliance Analyst (CIPP or equivalent; CAD \$100–130/hour, ~400 hours)
- Optional Privacy Consultant (50–100 hours, CAD \$200–250/hour, as-needed basis)
- NorthStream internal: CISO, IT Operations Manager, Privacy Officer (part-time, 10–30 hours/week)

Key Tools: OpenSCAP (free), Lynis (free), Nessus Policy Compliance (CAD \$3K–5K annually), AWS Config, CloudTrail logs, shared assessment workbook, video conferencing, file sharing

Final Deliverables:

1. **Comprehensive Compliance Assessment Report** (10–15 pages + appendices):
 - Executive Summary: Scope, key findings (Critical/High/Medium/Low counts), overall compliance rating, high-level recommendations
 - Assessment Methodology & Scope: Regulations, framework, tools, team composition
 - Detailed Findings: Organized by NIST CSF Function with finding description, current condition (evidence), required condition (regulation/standard), severity, root cause, compliance mapping
 - NIST CSF Maturity Assessment: Current-state vs. target-state rating for each Function
 - Remediation Roadmap: For each Critical & High finding – remediation steps, timeline, cost estimate, responsible owner, success criteria, target completion date
2. **Appendices:** References (NIST CSF, GDPR, PIPEDA, Law 25, CIS, SOC 2), sample interview questions, compliance tracking checklist, risk rating criteria table
3. **Executive Presentation** (30–45 minutes): 5–7 slides covering scope, critical findings + risk ratings, remediation roadmap (timelines, costs, owners), compliance metrics
4. **Quarterly Remediation Tracking Reports** (Q2, Q3, Q4 2026): Status on completed/in-progress/blocked remediations

KEY FINDINGS ANTICIPATED

Based on Project Task 3 prior analysis, assessment will likely identify these **CRITICAL gaps requiring immediate remediation**^[1]:

1. **Privacy Officer Appointment (Law 25 Articles 3–8):** Gap – no designated full-time Privacy Officer. Remediation timeline: Immediate consultant engagement + 3–6 month permanent hire. Owner: CISO/HR.
2. **Incident Response Plan – GDPR Article 33 Compliance:** Gap – incident response procedures lack explicit **72-hour DPA notification requirement** (CNIL-France, BfDI-Germany, AP-Netherlands). Remediation: Update IRP with DPA contact matrix, notification procedures, retention of breach notification logs. Timeline: 4 weeks. Owner: CISO/Privacy Officer.
3. **Backup Encryption – GDPR Schrems II Compliance (Article 32):** Gap – S3 backups encrypted with AWS-managed keys (AWS-provided) rather than **customer-managed AWS KMS CMK**. Risk: EU data stored with non-customer-controlled keys may violate GDPR Schrems II requirements. Remediation: Migrate to AWS KMS Customer Master Keys for all EU backup data. Timeline: 8 weeks. Owner: Security Architect/IT Operations.
4. **SIEM/Continuous Monitoring (PR.CM-01, DE.CM-01):** Gap – CloudWatch basic monitoring only, no Security Information & Event Management (SIEM) integration or automated threat detection. Remediation: Deploy SIEM tool (Splunk, ELK Stack, AWS Security Hub) with alerting rules for suspicious activity. Timeline: 12 weeks. Owner: Security Operations/IT Operations.
5. **Documentation:** Missing or incomplete security policies (encryption, access control, breach notification, vendor management, training). Remediation: Develop/update 7 core policies. Timeline: 6 weeks. Owner: CISO/Privacy Officer.

REFLECTION & PROJECT INTEGRATION

This Assessment Plan operationalizes findings from **Project Tasks 1–3**: Task 3 identified Privacy Officer appointment gap (Law 25 Articles 3–8), Task 3 exposed incident response plan deficiency (lacking GDPR Article 33 72-hour DPA procedures), and Tasks 1–2 established GDPR Article 32 encryption and PIPEDA Principle 4.7 safeguards as core compliance obligations. This Plan translates abstract regulatory requirements into concrete, measurable assessment activities with timelines, costs, and clear remediation ownership, enabling NorthStream to achieve regulatory compliance by end of 2026.

REFERENCES

[1] NorthStream Technologies Project Materials – Legal Requirements Register, GDPR vs PIPEDA Matrix, Framework Selection & Control Mapping (Projects 1–3)

[2] CIS Benchmarks. Center for Internet Security. <https://www.cisecurity.org/cis-benchmarks>

[3] NIST Cybersecurity Framework 2.0. National Institute of Standards and Technology. <https://www.nist.gov/cyberframework>

Document Prepared By: HASSANI Mohammad Salem

Module: Module 5 – Developing Assessment Plan

Project Task: 4

Status: READY FOR SUBMISSION